

BreachLens

Security Vulnerability Assessment Report

Target: https://wordpress-test.local
Scan Date: 2026-06-11
Report Generated: 2026-06-11 23:51
Prepared For: Demo User (demo.breachlens@gmail.com)

Overall Risk Score: 53.2/100 — High

1. Executive Summary

BreachLens conducted a comprehensive security assessment of **https://wordpress-test.local** on 2026-06-11. The scan identified **8** security vulnerabilities with an overall risk score of **53.2/100 (High)**. The estimated total financial exposure is **■87.8L**.

Key Metrics

Metric	Value
Target URL	https://wordpress-test.local
Total Vulnerabilities	8
Critical	2
High	3
Medium	2
Low	1
Overall Risk Score	53.2/100
Risk Level	High
Estimated Financial Exposure	■87.8L

Priority Action: Immediately remediate SQL Injection and Authentication Weakness and Insecure Direct Object Reference (IDOR) vulnerabilities.

2. Security Posture Assessment

Security Posture Score: 26/100 — Poor



Reason: Weak security posture. Critical vulnerabilities detected that require immediate remediation.

3. Compliance Assessment

Framework	Compliance Score	Status
OWASP Top 10	38%	Non-Compliant
GDPR Readiness	40%	Partially Ready
ISO 27001 Readiness	63%	Partially Ready

4. Vulnerability Details

1. SQL Injection **[Critical]** Risk: 96.0/100

Description: SQL injection vulnerability detected in the login form at <https://wordpress-test.local/login>. The 'username' parameter is directly concatenated into SQL queries without parameterization.

Recommendation: Use parameterized queries / prepared statements. Implement input validation and use an ORM framework.

Breach Probability: 99%

Estimated Financial Loss: ■26.5L

Estimated Fix Cost: ■1.1L

2. Authentication Weakness **[Critical]** Risk: 88.0/100

Description: The login system at <https://wordpress-test.local/login> lacks rate limiting, account lockout, and multi-factor authentication. Brute force attacks are feasible.

Recommendation: Implement rate limiting, account lockout after failed attempts, and multi-factor authentication. Use strong password policies.

Breach Probability: 93%

Estimated Financial Loss: ■16.0L

Estimated Fix Cost: ■1.0L

3. Cross-Site Scripting (XSS) **[High]** Risk: 64.5/100

Description: Reflected XSS vulnerability found in the search functionality at <https://wordpress-test.local/search>. User input in the 'q' parameter is rendered without sanitization.

Recommendation: Implement output encoding using Content Security Policy (CSP). Sanitize all user inputs with libraries like DOMPurify.

Breach Probability: 75%

Estimated Financial Loss: ■13.8L

Estimated Fix Cost: ■44,736

4. Cross-Site Request Forgery (CSRF) **[High]** Risk: 51.0/100

Description: Forms at <https://wordpress-test.local> lack CSRF tokens. An attacker can craft malicious requests that execute authenticated actions without user consent.

Recommendation: Implement anti-CSRF tokens for all state-changing operations. Use SameSite cookie attribute and validate Origin headers.

Breach Probability: 68%

Estimated Financial Loss: ■8.5L

Estimated Fix Cost: ■51,508

5. Insecure Direct Object Reference (IDOR) [High] Risk: 66.8/100

Description: IDOR vulnerability in API endpoint <https://wordpress-test.local/api/users>. User IDs are sequential and accessible without proper authorization checks.

Recommendation: Implement proper access control checks. Use UUID-based identifiers and validate user ownership of resources.

Breach Probability: 87%

Estimated Financial Loss: ■13.3L

Estimated Fix Cost: ■56,464

6. Open Directory Listing [Medium] Risk: 27.0/100

Description: Directory listing is enabled on the server at <https://wordpress-test.local/backup>, exposing sensitive files including configuration backups and database dumps.

Recommendation: Disable directory listing on the web server. Configure appropriate directory permissions and use index files.

Breach Probability: 47%

Estimated Financial Loss: ■6.0L

Estimated Fix Cost: ■33,566

7. Missing Security Headers [Medium] Risk: 27.0/100

Description: The application at <https://wordpress-test.local> is missing critical security headers: X-Content-Type-Options, X-Frame-Options, Strict-Transport-Security, and Content-Security-Policy.

Recommendation: Add security headers: Strict-Transport-Security, X-Content-Type-Options, X-Frame-Options, Content-Security-Policy, and Referrer-Policy.

Breach Probability: 37%

Estimated Financial Loss: ■2.8L

Estimated Fix Cost: ■20,756

8. Server Information Disclosure [Low] Risk: 5/100

Description: Server version information is exposed in HTTP response headers at <https://wordpress-test.local>. This aids attackers in targeting known vulnerabilities.

Recommendation: Disable server banner in response headers. Configure web server to hide version details.

Breach Probability: 13%

Estimated Financial Loss: ■85,544

Estimated Fix Cost: ■6,310

5. Breach Scenario Analysis

Scenario 1: SQL Injection [Critical] — Risk Score: 96.0/100

Attack Path: SQL Injection Vulnerability Detected → Database Query Manipulation → Unauthorized Data Extraction → Sensitive Customer Data Exposure → Credential Harvesting → Full Database Compromise

Business Impact: Complete database compromise leading to theft of customer PII, financial records, and authentication credentials.

Estimated Financial Impact: ■26.5L

Risk Level: Critical

Scenario 2: Authentication Weakness [Critical] — Risk Score: 88.0/100

Attack Path: Weak Authentication Mechanism Identified → Brute Force Attack Execution → Account Takeover → Privilege Escalation → Admin Panel Access → Full System Compromise

Business Impact: Unauthorized administrative access allowing complete system takeover, data manipulation, and service disruption.

Estimated Financial Impact: ■16.0L

Risk Level: Critical

Scenario 3: Cross-Site Scripting (XSS) [High] — Risk Score: 64.5/100

Attack Path: XSS Vulnerability Identified → Malicious Script Injection → User Session Hijacking → Cookie Theft → Phishing Attack Delivery → Credential Theft

Business Impact: Session hijacking and credential theft affecting multiple users, leading to account takeovers and data breaches.

Estimated Financial Impact: ■13.8L

Risk Level: High

Scenario 4: Cross-Site Request Forgery (CSRF) [High] — Risk Score: 51.0/100

Attack Path: CSRF Vulnerability Identified → Malicious Request Crafting → Authenticated Action Execution → Unauthorized Transactions → Account Manipulation → Financial Fraud

Business Impact: Ability to execute unauthorized actions on behalf of authenticated users, enabling fraud and data manipulation.

Estimated Financial Impact: ■8.5L

Risk Level: Medium

Scenario 5: Insecure Direct Object Reference (IDOR) [High] — Risk Score: 66.8/100

Attack Path: IDOR Vulnerability Detected → Parameter Manipulation → Unauthorized Resource Access → User Data Exposure → Mass Data Scraping → Privacy Violation

Business Impact: Unauthorized access to sensitive user data enabling mass data scraping and severe privacy violations.

Estimated Financial Impact: ■13.3L

Risk Level: High

6. Financial Risk Analysis

Category	Amount
Total Estimated Financial Exposure	■87.8 Lakh
Total Remediation Cost	■4.2 Lakh
Potential Savings (Loss - Fix)	■83.5 Lakh
Highest Impact Vulnerability	SQL Injection (■26.5 Lakh)

Return on Security Investment (ROSI): For every ■1 spent on remediation, approximately ■1972.9 in potential loss is mitigated. Investing in security now can prevent significant financial impact.

7. Security Recommendations

Immediate Actions (Critical/High Priority)

- Apply security patches and updates for all identified critical vulnerabilities
- Implement parameterized queries to prevent SQL injection attacks
- Deploy Web Application Firewall (WAF) for immediate protection
- Enable multi-factor authentication for all administrative accounts
- Fix broken access control mechanisms (IDOR, privilege escalation)

Short-term Actions (Medium Priority)

- Configure comprehensive security headers (CSP, HSTS, X-Frame-Options)
- Implement proper input validation and output encoding
- Disable directory listing and sensitive information exposure
- Set up automated vulnerability scanning in CI/CD pipeline
- Implement rate limiting and DDoS protection

Long-term Actions (Low Priority)

- Establish a bug bounty program for continuous security testing
- Conduct regular security awareness training for development team
- Implement Security Development Lifecycle (SDL) practices
- Schedule periodic third-party penetration testing
- Develop and test an incident response plan

8. Conclusion

The security posture of **https://wordpress-test.local** is rated **Poor**, indicating significant security weaknesses that require immediate attention. The presence of **2** critical and **3** high-severity vulnerabilities exposes the organization to substantial risk. Estimated financial exposure is **■87.8 Lakh**. We strongly recommend immediate remediation starting with the highest-risk findings.

This report is generated automatically by BreachLens Security Assessment Platform. The findings are based on automated scanning and should be verified by a qualified security professional. Risk scores and financial estimates are indicative and may vary based on actual exploitation scenarios.